INFORME DE AUDITORÍA DE SEGURIDAD WEB

Caso de estudio de portafolio — Tienda en línea (PrestaShop)

Objetivo	https://www.tienda-ejemplo.com (dominio anonimizado para portafolio)
Tipo de auditoría	Reconocimiento externo pasivo / auditoría de seguridad
Plataforma detectada	PrestaShop (PHP) con CDN Cloudflare
Fecha de auditoría	Junio 2026
Auditor	Brandon García — auditoría realizada con autorización del propietario del sitio
Clasificación	Caso de estudio — datos identificativos anonimizados

1. Resumen Ejecutivo

Se realizó una auditoría de seguridad de caja negra sobre una tienda en línea basada en PrestaShop, protegida por Cloudflare WAF. El objetivo fue identificar vulnerabilidades accesibles desde el exterior sin credenciales, con el fin de reforzar la postura de seguridad del sitio.

La auditoría identificó 3 hallazgos críticos, 4 de severidad media y confirmó 4 controles de seguridad correctamente implementados.

🔴 **CRÍTICO (3)**	**composer.lock expuesto, panel de hosting accesible, Makefile expuesto**
🟡 **MEDIO (4)**	**Sesión sin expiración razonable, cookies sin flag Secure, headers ausentes, dependencias de desarrollo en producción**
🟢 **POSITIVO (4)**	**HTTPS forzado, Cloudflare WAF, HttpOnly, SameSite**

2. Metodología

Reconocimiento externo pasivo, usando únicamente herramientas de código abierto y técnicas no destructivas. No se realizaron intentos de explotación activa ni acceso no autorizado a sistemas.

- curl — análisis de cabeceras HTTP y recuperación de recursos
- ffuf v2.1.0 — enumeración de directorios y rutas
- grep / bash — análisis de código fuente HTML y respuestas HTTP

Fases: reconocimiento (fingerprinting y robots.txt), enumeración de rutas, análisis de respuestas y revisión de cookies/cabeceras.

3. Hallazgos Críticos

HAL-001 — Archivo composer.lock expuesto públicamente

Severidad	**CRÍTICO**
URL afectada	https://www.tienda-ejemplo.com/composer.lock
Riesgo	Exposición del stack tecnológico completo con versiones exactas
CVSS estimado	7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)

El archivo composer.lock estaba accesible sin autenticación y revelaba el listado completo de dependencias PHP con versiones exactas, incluyendo paquetes de desarrollo desactualizados (PHPUnit, Doctrine DBAL, symfony/phpunit-bridge) que facilitan identificar CVEs conocidos.

Recomendación: bloquear el acceso al archivo vía .htaccess (Deny from all) y excluir dependencias de desarrollo del entorno de producción con composer install --no-dev.

HAL-002 — Panel de hosting accesible desde Internet

Severidad	**CRÍTICO**
URL afectada	https://panel.tienda-ejemplo.com
Riesgo	Acceso al panel de administración del hosting sin restricción de IP
CVSS estimado	8.1 (AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H)

El subdominio del panel de hosting respondía públicamente, exponiéndolo a ataques de fuerza bruta y credential stuffing.

Recomendación: restringir el acceso por IP fija, habilitar 2FA y bloqueo automático tras intentos fallidos.

HAL-003 — Archivo Makefile expuesto con rutas internas

Severidad	**CRÍTICO**
URL afectada	https://www.tienda-ejemplo.com/Makefile
Riesgo	Revelación de estructura de directorios y herramientas de build internas

Recomendación: bloquear el acceso al archivo vía .htaccess.

4. Hallazgos de Severidad Media

- HAL-004 — Cookie de sesión con Max-Age de ~56 años: la sesión nunca expira en la práctica. Recomendación: limitar session.gc_maxlifetime a 3600 segundos.
- HAL-005 — Inconsistencia en el flag Secure de cookies: una cookie carecía del flag, exponiéndola a transmisión sin cifrar. Recomendación: forzar HTTPS en toda la plataforma.
- HAL-006 — Headers de seguridad ausentes (X-Frame-Options, Content-Security-Policy, X-Content-Type-Options, Permissions-Policy). Recomendación: agregarlos vía .htaccess.
- HAL-007 — Dependencias de desarrollo (PHPUnit, etc.) presentes en producción. Recomendación: excluirlas del despliegue en CI/CD.

5. Controles Correctamente Implementados

- HTTPS forzado (redirección 301 activa)
- Cloudflare WAF activo, bloqueando peticiones maliciosas
- Flag HttpOnly en cookies de sesión
- SameSite=Lax en cookies (protección parcial contra CSRF)
- HTTP/2 + QUIC (h3) activo

6. Conclusiones

El sitio presentó una postura de seguridad mixta: controles importantes correctamente implementados (HTTPS, WAF, cookies protegidas), pero con exposición crítica de archivos de configuración y del panel

de hosting. La mayoría de los hallazgos críticos podían remediarse en menos de una hora con cambios de configuración simples.

7. Referencias

- OWASP Top 10 — https://owasp.org/www-project-top-ten/
- PrestaShop Security Guide
- Cloudflare Security Headers
- CVE Database — https://cve.mitre.org
- Mozilla HTTP Headers Guide

— Fin del informe —